CorpLink PHP Lab

Challenge 03 — Local File Inclusion

PHP EXPLOITATION · XE107-M04 · CYBERIUM ARENA

Questions: 9 · Topic: Local File Inclusion · Path Traversal

QUESTION 01 RECONNAISSANCE

Extract the lab zip using the password `infected` and start it by running `bash start.sh` inside the extracted folder. Open your browser and navigate to `http://localhost:8080`. What is the title shown on the Challenge 03 card?

HOW TO SOLVE

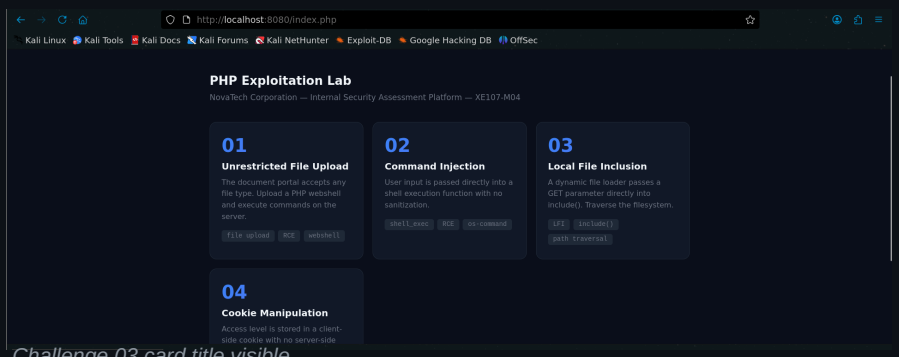
01 Extract the zip file using the password `infected`.

02 Navigate into the extracted folder and run `bash start.sh` to start the lab.

03 Open your browser and go to `http://localhost:8080`.

04 Find the Challenge 03 card on the overview page and read its title.

SCREENSHOTS



Lab overview page — Challenge 03 card title visible.

ANSWER

Local File Inclusion

QUESTION 02 RECONNAISSANCE

Navigate to Challenge 03. The Documentation Viewer has a filename input field with a hint shown below it. What is the default filename already entered in the field?

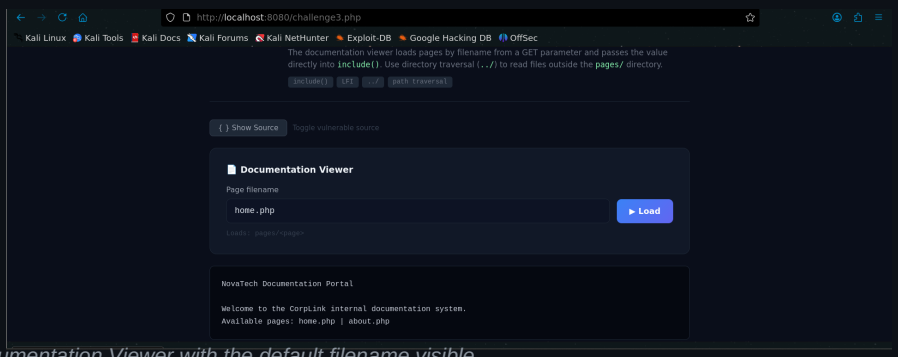
HOW TO SOLVE

01 Click on Challenge 03 in the navigation or on the overview card.

02 Look at the Documentation Viewer input field.

03 Read the filename that is pre-filled in the input field.

SCREENSHOTS



Challenge 03 — Documentation Viewer with the default filename visible.

ANSWER

home.php

QUESTION 03 SOURCE CODE ANALYSIS

Click the { } Show Source button on Challenge 03. What PHP function is used to load the requested page file?

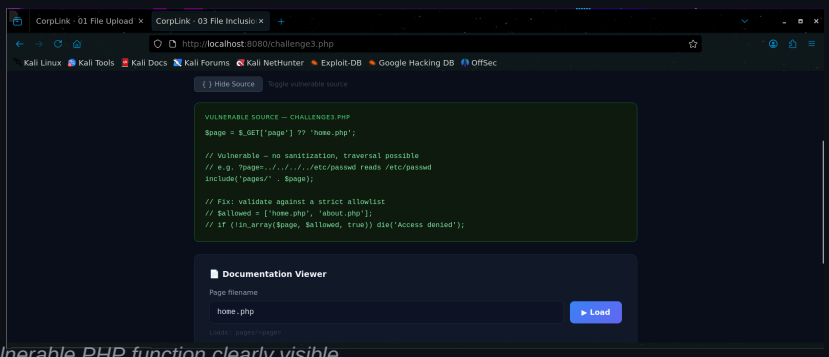
HOW TO SOLVE

01 Click the { } Show Source button at the top of Challenge 03.

02 Read the vulnerable source code that appears.

03 Find the PHP function responsible for loading (including) the requested file.

SCREENSHOTS



Source code panel — vulnerable PHP function clearly visible.

ANSWER

include

QUESTION 04 SOURCE CODE ANALYSIS

Looking at the source code, the user input is prepended with a directory path before it is passed to the include function. What is that directory path (including the trailing slash)?

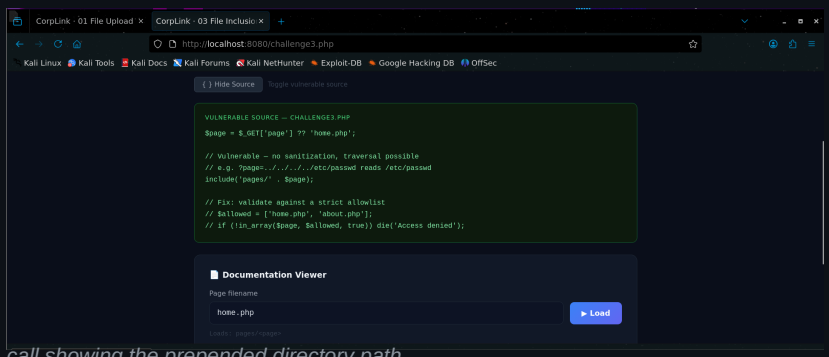
HOW TO SOLVE

01 The source code from Q3 is still open.

02 Look at the `include()` call on the vulnerable line.

03 Find the string concatenated before the user input — that is the directory prepended to every filename.

SCREENSHOTS



Source code — include() call showing the prepended directory path.

ANSWER

pages/

QUESTION 05 EXPLOITATION

Enter `about.php` in the filename field and click Load. The output panel displays information about the application. What is the support email address shown?

HOW TO SOLVE

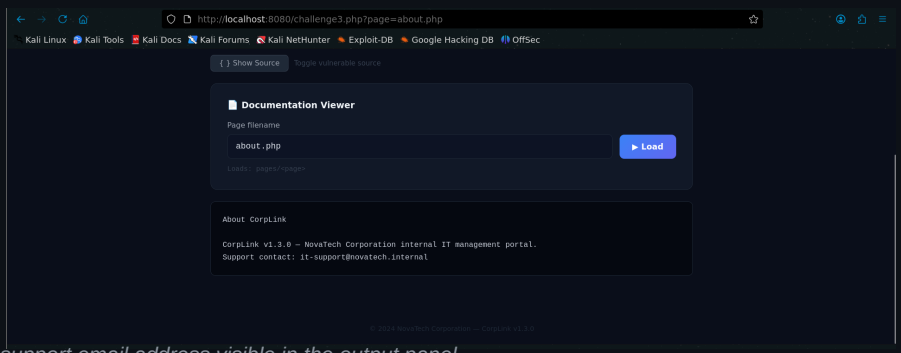
01 In the filename field, clear the default value and type `about.php`.

02 Click the Load button.

03 Read the terminal-style output panel that appears below the form.

04 Find the support contact field and read the email address.

SCREENSHOTS



about.php loaded — support email address visible in the output panel.

ANSWER

it-support@novatech.internal

QUESTION 06 EXPLOITATION

Enter `about.php` in the filename field and click Load. Look at the browser address bar after the page loads. What is the name of the GET parameter used to pass the filename to the server?

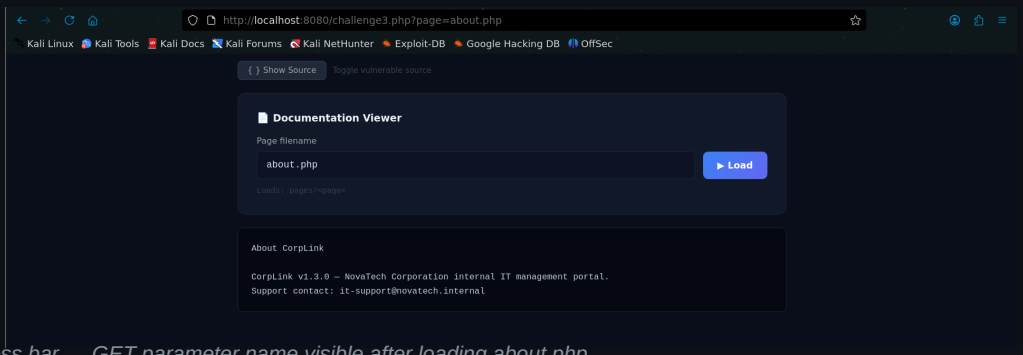
HOW TO SOLVE

01 Enter `about.php` in the filename field and click Load.

02 Look at the URL in the browser address bar after the page reloads.

03 The URL shows a query string — read the parameter name that appears before the = sign.

SCREENSHOTS



Browser address bar — GET parameter name visible after loading about.php.

ANSWER

page

QUESTION 07 EXPLOITATION

Use directory traversal to read `/etc/passwd` on the server. What is the username on the very last line of the file?

HOW TO SOLVE

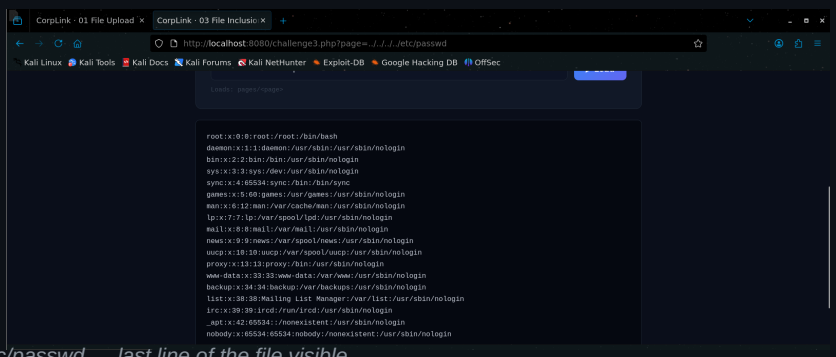
01 Think about how many `../` sequences are needed to climb from `pages/` to the filesystem root.

02 Construct a traversal payload: `../../../../etc/passwd`.

03 Enter the payload in the filename field and click Load.

04 Scroll to the very last line — the username is the text before the first colon.

SCREENSHOTS



Directory traversal to /etc/passwd — last line of the file visible.

ANSWER

nobody

QUESTION 08 EXPLOITATION

Use directory traversal to read `/etc/group`. Find the `www-data` line. What is its GID — the numeric value in the third field?

HOW TO SOLVE

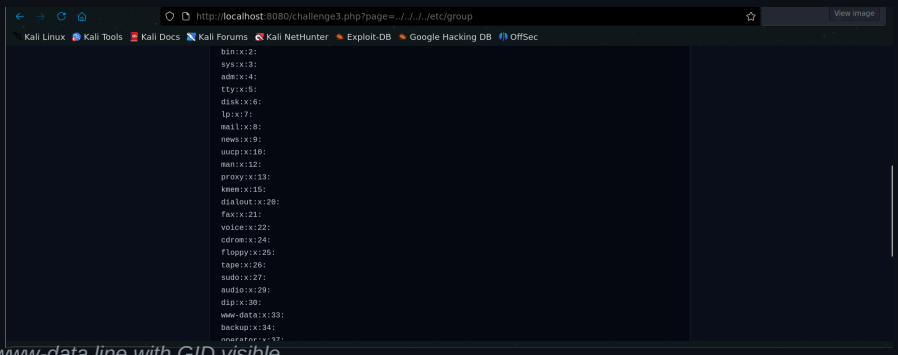
01 Replace `/etc/passwd` in your traversal payload with `/etc/group`.

02 Enter the updated payload in the filename field and click Load.

03 Find the line starting with `www-data` in the output.

04 The GID is the number between the second and third colon on that line.

SCREENSHOTS



/etc/group output — www-data line with GID visible.

ANSWER

33

QUESTION 09 MITIGATION

Click { } Show Source and read the commented-out fix at the bottom. What PHP function is used to validate the filename against a strict allowlist?

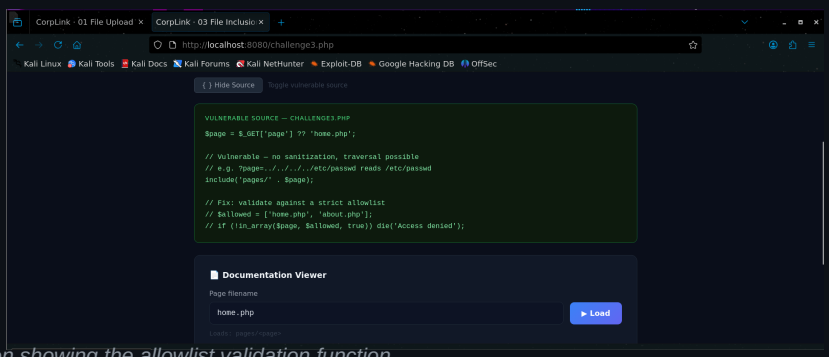
HOW TO SOLVE

01 Click { } Show Source — the fix is in the commented-out section at the bottom.

02 Read the PHP function that checks whether the input matches one of the allowed filenames.

03 Note that the function takes the input value, the allowed array, and a strict mode flag.

SCREENSHOTS



Source code — fix section showing the allowlist validation function.

ANSWER

in_array()